2026年 日本の情報漏えい・不正アクセス・ランサムウェア事案 原因別精査レポート

対象期間：2026年1月1日〜10月22日（2026年10月23日 0時時点の公表情報）

公開：Synctank-jp / ライセンス：CC BY 4.0（出典を明記すれば自由に転載・改変できます）

> このレポートは、各社・各機関の公式発表と専門メディアの報道を突き合わせて作成しています。件数は「最大」「可能性」「おそれ」の区別を保持し、続報で訂正されたものは変遷を記録しています。裏取りできなかった数字は「未確認」と明記しています。2026年10月22日時点の公表情報に基づいています。誤りの指摘は Issue へ。

結論サマリー

1. **全体像**：2026年は上場企業の100万件超漏えいが10月5日時点で10件となり、2025年通年の6件をすでに上回った（東京商工リサーチ）。その後も10月だけでソースネクスト（2,252万）、バーガーキング（1,118万）、カプコン（1,177万・全世界）、skyticket（1,464万）と1,000万件級が続き、本レポートの主要60事案のうち1,000万件超は8件にのぼる。
2. **最多の手口**：Webアプリ・APIの脆弱性や仕様・機能の悪用が最も多い（主因として18件）。内容は、内部APIの不正利用、アプリ解析によるAPI特定（A2B攻撃）、管理機能の不正操作、既知・未知の脆弱性悪用である。
3. **未公表率**：主要60件のうち、具体的な手口まで公表されたのは20件（33%）にとどまる。「不正アクセス」「調査中」のみで侵入経路が完全に未公表なのが21件（35%）、「侵害部位や委託先名だけ公表」が19件（32%）で、手口が特定できないものは合計40件（67%）に達する。
4. **波及構造**：KDDI（ISP6社）、Eストアー（7,858店）、IDCFクラウド（495組織）、スカラ「i-ask」（最大5社）、Studio（全登録顧客）、コミューン（LINEヤフー・Sansan・パナソニック等）など、委託先・SaaS・クラウド基盤の1件の侵害が多数の組織へ広がった。
5. **AIの確定度**：攻撃インフラ上でのAI利用は「確認」済み（JPCERT/CC 10/15、GMOイエラエ 10/19）。個別漏えい事案への関与は「推測」の段階にあり、被害企業・国による公式な紐付けは10月22日時点でない。
6. **PHP2Shell（CVE-2026-109618/109619）**：10月22日にバルテックが「PHPの脆弱性を標的とした攻撃」と公表したが、同日夜に「自社サービス自体の脆弱性」と訂正。**国内でPHP2Shellによる侵害を公表した組織は10月22日時点でゼロ**のまま（Cloudflareは公開後2時間で数十万件、その後数百万件の攻撃試行を観測）。
7. **ランサムウェア**：警察庁統計で2026年上半期は123件と半期最多（製造業37件、中小企業79件）。侵入経路はVPN機器が最多で、大量漏えい（Web/API層）と業務停止（VPN/RDP層）の二層構造になっている。

1. 調査方法と「原因の確定度」の定義

- **対象**：2026年1月1日〜10月22日に国内組織が公表した事案のうち、①影響10万件以上、または②業務停止・社会的影響が大きいものを「主要事案」として60件を抽出した（IDCF波及先のイズミとマウスコンピューター、上新電機とセカンドリテイリングはそれぞれ1行にまとめた）。
- **除外**：メール誤送信・媒体紛失などの単純な人為ミス（例：九州電力送配電の外部記憶媒体所在不明）、内部不正（ユナイテッドアローズ元従業員の持ち出し）、海外子会社のみの事案（エイチ・アイ・エスのタイ

現地法人）、攻撃者の主張のみで企業が確認していないもの。

- **手口の型**：各事案に「主因」を1つ割り当てた。委託先・基盤経由は別途「波及」として第5章で集計した。
- **原因の確定度**：
- **A（手口公表）**：脆弱性・機能悪用・認証情報の窃取など、具体的な手口が公式に示されたもの
- **B（部位のみ）**：侵害されたシステム名、委託先名、ランサムウェアであることは公表されたが、侵入手口が未公表のもの
- **C（未公表）**：「不正アクセス」「調査中」のみのもの
- **出典の扱い**：各社公式発表と専門メディア（ITmedia、INTERNET Watch、ScanNetSecurity、Security NEXT、piyolog、日経、NHK等）を優先。民間まとめサイト（westeria.jp、satimo.org、directcloud.jp等）のみに依拠する数字は「未確認」と明記。

手口の型（凡例）

型	内容
①	Webアプリ・APIの脆弱性、仕様・機能の悪用（A2B攻撃、SSRF、認証なしAPI、アプリ埋め込み鍵、管理機能の不正操作）
②	盗まれた・弱い認証情報（フィッシング、委託先PC感染、管理アカウント乗っ取り）
③	委託先・SaaS・クラウド基盤経由の波及（起点側の手口が不明なもの）
④	設定・管理の不備
⑤	VPN・リモートアクセス機器の脆弱性
⑥	ランサムウェア
⑦	侵入経路未公表・調査中

2. 主要事案一覧（公表日順・60件）

公表日	組織・サービス	件数（最新公式値と変遷）	機微情報	型/確定度	停止・復旧	出典
5/13	メディカ出版	641,000人（おそれ、重複含む可能性）	—	⑥/B	—	同社公表
5/21	穴吹ハウジングサービス	207,773件	—	⑥/B	—	同社公表
6/19	2りんかんイエローハット	3,179,454名（最終報）※公式未照合＝未確認	—	①/A	—	satimo-blog
6/23→7/6	KDDI（ISP事業者向けメール基盤）	最大1,422万件→メールアドレス12,231,954件・パスワード7,616,173件（7/21訂正値）	**メールパスワード**	①（第三者製ソフトのゼロデイ）＋波及/A	ISP6社がパスワード変更・強制変更	INTERNET Watch
6/30	アフラック生命保険	約438万人→約440万人（7/13第二報）	**口座情報約22万人**	⑦/C	—	同社公表
7/17	アサヒグループHD（2025年9月発生分）	約228.9万件（おそれ）	—	⑥/B	国内受注・出荷停止（2025年）	同社公表
7/24→9/15	ムラウチドットコム	約772万件→7,716,811件	—	①/A（Webシステムの脆弱性）	—	同社公表
7/31→9/24	EPARKリラク＆エステ	約2,218万レコード（第二報。人数換算困難）	—	⑦/C	—	同社公表

公表日	組織・サービス	件数（最新公式値と変遷）	機微情報	型/確定度	停止・復旧	出典
8/1→10/16	Eストアー「ショップサーブ」	延べ885万件→約2,335万6,000人・7,858店（最終報）	**カード名義・番号の一部・有効期限 約209万6,900人**	①（アプリ脆弱性で不正プログラム実行）＋波及/A	—	ビジネス+IT
8/19→9/10	さくらインターネット	1,360,563アカウント	—	⑦/C	—	同社第三報
8/28→10/15	イエローハット（WEB作業予約）	最大1,801,499名→1,797,124名	—	⑦/C	—	同社公表
9/11	デジタル庁 GSS	約24.6万件（可能性）	職員等情報	⑤/A（VPN機器の脆弱性）	—	デジタル庁公表
9/16	Helpfeel「Gyazo」	ユーザーデータ約2,362万件＋画像メタデータ約4.9億件	**パスワードハッシュ**	①/A（画像サーバーの脆弱性で任意コマンド実行）	一時停止	同社公表
9/25	ファインズ（予約システム）	1,536,322件	—	⑦/C	—	同社公表
9/25→9/29	タイムズモビリティ「タイムズカー」	約660万アカウント、うち本人確認書類画像約160万件	**運転免許証画像**	⑦/C	継続。免許証画像は10月末までに全削除方針	ITmedia
9/26	京王電鉄グループ	件数非該当	—	⑥/B	決済・ポイント停止、9/30カード決済復旧	同社広報
9/27	スターツ出版「OZmall」	最大約45万人	—	①/B（サイトの脆弱性）	—	同社公表
9/28	手間いらず「TEMAIRAZU」	予約者最大約445万人	宿泊予約情報	③/C	—	同社公表
9/29→9/30	セイコーマート（アプリ）	572,022人（第三報）※一部まとめは574,647人と記載	—	⑦/B（アプリサーバー経由）	—	同社公表
9/29→10/16	ヤマト運輸「クロネコ代金後払い」	利用者約526万件・届け先約5万件・加盟店約4,100件	—	⑦/C	—	同社公表
9/30	佐川急便	約100日分の送り主・届け先	—	①/B	Webサービス9つ停止	同社公表
10/2	大阪公立大学	—	—	⑥/B	全授業約1週間休講	同大公表
10/2	第一生命（人事システム）	従業員・退職者約12万名	—	⑦/C	—	同社公表
10/5	物語コーポ「焼肉きんぐ」	10,788,963件	—	⑦/B（アプリ会員管理システム）	—	同社公表
10/5	GMOリサーチ&AI「infoQ」	894,082件※一部まとめは最大948,498件	ポイント	①/A（サイトのソフトウェア脆弱性）	停止・再開未定	同社公表
10/5〜8	スカラコミュニケーションズ「i-ask」	最大5社・延べ713,126件（大和証券約11万人、シチズン約10万名、損保ジャパン約6万件、オリックス生命）	**証券口座番号**	②（管理サイト不正ログイン→不正プログラム設置）＋波及/A	—	日経クロステック
10/6	ミスターマックス	最大1,735,154人	—	①/A（ソフトウェア機能の不正利用）	—	同社公表

公表日	組織・サービス	件数（最新公式値と変遷）	機微情報	型/確定度	停止・復旧	出典
10/6	旭化成「Pharma DIGITAL」	最大約51.4万名	医療従事者情報	③/C（委託先：医薬情報ネット）	—	同社公表
10/7	IDCフロンティア「IDCFクラウド」	495の企業・自治体が障害。第5報で4ゾーンのデータ流出なしと判断、ポータルで48社の登録情報に不正照会	—	⑥＋波及/B	東日本リージョン1停止、10/18バックアップ提供再開、復旧時期未定	@IT
10/8	第一興商	約872万4,000件（おそれ）	従業員情報含む	②（委託先の従業員PCがマルウェア感染）＋波及/A	—	同社公表
10/8	ローソン「ローソンID」	2,155,345件	—	①/B（アプリ関連システムの不正利用）	—	同社公表
10/8	ユーザベース「NewsPicks」	メール最大32.3万件	**カード情報の一部 最大36.2万件**	⑦/B（業務用管理ツール）	—	同社公表
10/9→10/16	アドベンチャー「skyticket」	約1,464万件（ハッシュ化パスワード約413万）。第2報でカード情報最大6,140名分を追加（第1報の「カード流出なし」を訂正）	**口座情報、カード番号・名義・有効期限**	①（管理機能の不正操作、経路の異なる3件）＋④（2018年以前の決済ログ残存）/A	—	日経
10/9→10/13	ブックオフ	6,383,279人（会員データ6,427,735件）	—	⑦/C	—	同社適時開示
10/9	ディップ「バイトル」	最大3,885,771件	メールアドレスのみ	①/A（仕様の不備）	—	同社公表
10/9→10/15	JR東日本（えきねっと等）	最大約206万件（可能性）→10/15「漏えいなし」と訂正	—	③（IDCF波及）/B	—	同社公表
10/9→10/15	JR九州（Web会員）	最大約130万件（可能性）→漏えいの事実確認されず	—	③（IDCF波及）/B	—	同社公表
10/9	コミューン「Commune」	約30.7万人（波及先：LINEヤフー DS.LAB 1,750名、Sansan、パナソニック等）	—	①（通信経路の不備で不正な会員登録・閲覧）＋波及/A	全コミュニティ停止→再開	セキュリティ対策Lab
10/13	ライドオンエクスプレスHD（銀のさら等）	最大約650万件（可能性）	—	⑥（利用サーバー運営会社がランサムウェア被害）＋波及/B	—	同社公表
10/13	アルカディア「SpeeCAN RAIDEN」	メールアドレス最大約313.6万件	自治体防災メール登録者	⑦/C（波及：自治体・学校）	—	同社公表
10/13	Fivot「IDARE」	129,659人	**残高・取引履歴**	③（業務用外部ソフトの脆弱性）/A	—	同社公表
10/14	アエナ（ECアプリ）	最大817,215人	—	①/A（機械的な連続アクセス）	—	同社公表
10/14	イズミ／マウスコンピューター	最大約40万件／約42万件	—	③（メルマガ委託先が使うIDCF）/B	—	各社公表
10/15	ソースネクスト	最大22,519,960件（可能性）	**パスワード**	①/A（会員情報取得APIの不正利用、10/9〜13）	全会員パスワード変更	同社公表
10/15	ビーケー・ジャパン（バーガーキング）	約1,118万件	—	⑦/C	—	同社公表

公表日	組織・サービス	件数（最新公式値と変遷）	機微情報	型/確定度	停止・復旧	出典
10/15	メドレー「@link」	最大787医療機関	**患者情報**	⑦/C	サービス停止	同社公表
10/15→10/21	NTTソルマーレ「コミックシーモア」	会員DB319件（ハッシュ化パスワード含む）＋システムログ最大約420万件（第4報、重複あり）	ハッシュ化パスワード（319件）	⑦/C（経路は「特定し対処」とするが非公表）	10/15から全面停止、再開未定	日経
10/16	日本経済新聞社（開発用クラウド）	約183万件（うち個人情報約15万件）	—	②/A（クラウド認証情報の窃取）	停止なし	同社公表
10/16	ファンケル／アテニア	393,785件／441,162件	—	⑦/B（ECサイト）	—	同社公表
10/16→10/20	Studio	全登録顧客のアカウント情報、フォーム送信内容、APIキー（LUUP 21,368件、ラクスル6,412件、埼玉県・京都市等）	**外部サービスのAPIキー**	①（一部機能の脆弱性）＋波及/A	全ユーザー一括ログアウト、鍵更新	同社公表
10/17	上新電機／セカンドリテイリング	件数不明（ゲオ側は漏えい確認されず）	—	⑦/C	一部サービス・通販停止	各社公表
10/19	H2O リテイリング／阪急阪神百貨店「H2O ID」	約126万件	—	⑦/B（予約サイト経由）	予約サイト・通販2サイト停止	同社公表
10/19	ユミルリンク「Cuenote FC」	延べ約900万件（試算）	メールアドレス	①（脆弱性を悪用した認証情報の取得）＋波及/A	—	同社公表
10/19	ニフティ（回線申込管理）	最大542,513件	—	⑦/C	—	同社公表
10/19	クリプトン「SONICWIRE」	最大約42万件	—	⑦/C	—	同社公表
10/19	パピレス「Renta!」	件数未公表	—	⑦/C	停止中	同社公表
10/20	NEC（開発・保守委託先）	件数非公表	—	②（委託先から窃取された正規アカウント悪用）＋⑥＋波及/A	顧客サーバーのファイル暗号化	同社公表
10/21→10/22	GMOインターネット「お名前.com デスクトップクラウド」	影響の可能性があるサーバー26,739件	**FX・証券取引ツールの口座ログイン情報**	⑦/C（侵入経路調査中）	10/21 4:00から全プラン停止、再開未定、10/22警察相談	GMO第2報
10/22	カプコン「CAPCOM ID」	全世界合計11,774,247件（メールアドレス、作成日時、最終ログイン日時・IP等）。うち43件は生年月日等、196件でパスワード不正変更	パスワード不正変更196件	⑦/C（「攻撃手段の特定・対応完了」とするが非公表）	停止なし。10/19検知・遮断	ITmedia
10/22	バルテック（MOT、勤怠・経費精算、POS等）	件数・種類は調査中	—	①/B（第一報「PHPの脆弱性」→同日「自社サービス自体の脆弱性」と訂正）	20以上のサービス停止、最短10/26復旧	INTERNET Watch

10万件未満・漏えい未確認だが原因が特徴的な事案（参考）

- ソフトバンク「My SoftBank」「My Y!mobile」「My Menu」：10/17に不正アクセスの試みを検知しWeb版を停止（アプリ版は継続）。10/21〜22に再開。漏えいの公表なし。

- ベネフィット・ワン（13,460名、アンケート機能の条件設定不備＝④）、集英社「HAPPY PLUS COMMUNITY」（2,835人、CMS設定不備＝④）、チケプラ（キャッシュ設定変更で他会員情報表示＝④）
- 楽天ドライブ（15,382アカウント、管理用アカウント認証情報の悪用＝②）、日経社員アカウント不正ログイン（1,646人、なりすましメール約9,000件＝②）
- リクルート「スタディサプリ」（3,687件、仕様不備＝①）、日本原子力研究開発機構（顔写真付き身分証画像など367件＝⑦）、JR九州グループ（1/19、従業員14,638人＝⑦）
- あきる野市（10/22、災害時職員連絡システムのアカウントへの不正アクセスで職員約500人分＝②）
- 大阪大学（委託先NECの個人情報漏えい、報告されていない協力会社と契約に基づかずファイル共有）

---

3. 手口（原因）の型別集計

3-1. 主要60事案の主因別集計

型	件数	構成比	代表事例
① Webアプリ・APIの脆弱性・仕様・機能悪用	18	30%	ソースネクスト（API不正利用）、Gyazo（RCE）、Eストアー、KDDI（ゼロデイ）、skyticket（管理機能）、ミスターマックス、ディップ、アエナ、Studio、ユミルリンク、コミューン、バルテック
② 盗まれた・弱い認証情報	4	7%	第一興商（委託先PCのマルウェア感染）、日経（クラウド認証情報）、i-ask（管理サイト不正ログイン）、NEC委託先
③ 委託先・SaaS・基盤経由（手口不明）	6	10%	JR東日本・JR九州・イズミ・マウス（IDCF）、手間いらず、旭化成、IDARE
④ 設定・管理不備（主因）	0	0%	主要事案ではskyticketの旧ログ残存が副因。小規模ではベネフィット・ワン、集英社、チケプラ
⑤ VPN・リモートアクセス機器	1	2%	デジタル庁GSS
⑥ ランサムウェア	7	12%	IDCF、京王、大阪公立大学、アサヒ、ライドオン（委託先）、メディカ出版、穴吹ハウジング
⑦ 侵入経路未公表・調査中	24	40%	タイムズカー、焼肉きんぐ、バーガーキング、ブックオフ、ヤマト、アフラック、コミックシーモア、お名前.com、カプコン
合計	**60**	100%	

3-2. 原因の確定度

確定度	件数	構成比	意味
A：手口まで公表	20	33%	①14件＋②4件＋③1件（IDARE）＋⑤1件
B：部位・委託先・ランサムウェアであることのみ公表	19	32%	⑥7件＋⑦5件（セイコーマート、焼肉きんぐ、NewsPicks、ファンケル、H2O）＋①4件（OZmall、佐川、ローソン、バルテック）＋③3件（IDCF波及先）。ランサムウェア7件はいずれも初期侵入経路が未公表
C：完全未公表（「不正アクセス」「調査中」のみ）	21	35%	⑦19件＋③2件（手間いらず、旭化成）

読み方

- 侵入経路が完全に未公表なのは35%で、手口が分からないもの（B＋C）は67%に達する。⑦の24件にも、焼肉きんぐ、バーガーキング、セイコーマート、H2O、カプコンのように「公式アプリ・会員管理システム・予約サイト・アカウント基盤」が侵入部位として示されたものが多い。JPCERT/CCの類型B（API経由

の不正操作）やNICTのA2B攻撃と同じ系統である可能性は高いが、各社が手口を公表していない以上、これは**推測**にとどまる。

- 民間集計も同じ傾向を示す。westeria.jpの2024〜2026年124件の手口タグでは「不正アクセス（経路未公表）」が34件で最多だった（Webサービス・アプリ経由26件、委託先・取引先経由28件、ランサムウェア27件、盗まれた・弱いID/パスワード17件、VPN・リモートアクセス機器13件、設定・管理不備10件。複数タグあり）。
- **⑤VPNが少ない点は「秋の漏えいラッシュ」の特徴であり、年間のランサムウェア全体では逆になる**。警察庁統計では、2026年上半期のランサムウェア感染経路（有効回答36件）はVPN機器18件、リモートデスクトップ9件だった。大量の個人情報漏えいはWeb・API層、業務停止型のランサムウェアはVPN・RDP層という二層構造である。

---

4. 業種別の分布（主要60事案）

業種	件数	主な事案	特徴
IT・クラウド・SaaS・通信	14	KDDI、Eストアー、さくら、Gyazo、IDCF、Studio、ユミルリンク、ソースネクスト、ニフティ、NEC、お名前.com、コミューン、SpeeCAN、バルテック	自社の被害がそのまま利用企業に波及する「起点」になりやすい
小売・EC	13	ムラウチ、イエローハット、2りんかん、セイコーマート、ミスターマックス、ローソン、ブックオフ、アエナ、ファンケル、H2O、ジョーシン／ゲオ、イズミ／マウス、クリプトン	公式アプリと会員IDが集中的に狙われた（ラックの分析では、被害企業に占める小売・ECの割合が2026年1〜5月の4.5%から6〜9月に23.6%へ上昇）
メディア・出版・コンテンツ・ゲーム	7	日経、NewsPicks、コミックシーモア、Renta!、OZmall、メディカ出版、カプコン	電子書籍2サービスが長期停止、カプコンは1,177万件
運輸・物流・モビリティ	6	タイムズカー、京王、ヤマト、佐川、JR東日本、JR九州	免許証画像、配送先情報など機微度が高い
飲食	4	焼肉きんぐ、バーガーキング、ライドオン、第一興商	アプリ会員1,000万件級が2件
金融・証券・保険・決済	4	アフラック、第一生命、大和証券ほか（i-ask）、IDARE	口座番号・残高など財産系情報
旅行・予約	4	skyticket、EPARK、ファインズ、手間いらず	予約SaaSの波及
医療・製薬	2	メドレー@link（787医療機関）、旭化成Pharma DIGITAL	患者情報（要配慮）
人材・調査	2	ディップ、infoQ	ポイントの換金被害
教育	1	大阪公立大学	休講
官公庁	1	デジタル庁GSS	VPN
製造・食品	1	アサヒ	出荷停止
不動産	1	穴吹ハウジング	ランサムウェア

解釈：大量漏えいはB2C（小売・飲食・運輸・コンテンツ）と、それを支えるIT基盤に偏っている。これに対し、警察庁のランサムウェア統計（2026年上半期123件）は製造業37件が最多で、中小企業が79件を占める。製造業は漏えい件数の大きな事案としては表に出にくいが、ランサムウェアの業務停止では最も多い業種である。

---

5. 波及型事案の構造

起点（委託先・SaaS・基盤）	起点の侵害手口	波及先・規模	備考
KDDI（ISP向けメール基盤）	第三者製ソフトの未知の脆弱性（5/16から侵害）	ISP6社（BIGLOBE、ニフティ、J:COM、コミュファ光、ピカラ光、CPI）、メール1,223万件・パスワード762万件	1,422万→1,223万に確定。au・UQメールは別設備で影響なし
Eストアー「ショップサーブ」	アプリ脆弱性→不正プログラム	7,858店、約2,335万6,000人	延べ885万件→名寄せ後の人数に修正
IDCフロンティア「IDCFクラウド」	ランサムウェア（経路未公表）	495の企業・自治体が障害。JR東日本（206万→漏えいなし）、JR九州（130万→確認されず）、イズミ40万、マウス42万	4ゾーンのデータ流出なしと判断（第5報）。SNS上の犯行声明は真偽不明
スカラコミュニケーションズ「i-ask」	管理サイトへの不正ログイン→不正プログラム設置	最大5社・延べ713,126件（大和証券、シチズン、損保ジャパン、オリックス生命。東武鉄道は痕跡なし）	同一サーバー上の利用企業DBが一括で取得された
Studio	一部機能の脆弱性	全登録顧客（LUUP、ラクスル、埼玉県、京都市、南日本放送など）	フォーム送信内容とAPIキーが対象。PPCと協議し連名報告も選択可能に
コミューン「Commune」	通信経路の不備による不正な会員登録・閲覧	約30.7万人。LINEヤフー DS.LAB 1,750名、Sansan、パナソニック等	10/6に全停止後、10/7に残存経路から再度閲覧が発生し遮断
ユミルリンク「Cuenote FC」	脆弱性を悪用した認証情報の取得	利用企業の配信先、延べ約900万件	5システムが対象
トイポ（顧客管理アプリ）	不正アクセス	JR九州フードサービス約2万6,900名	—
手間いらず「TEMAIRAZU」	不正アクセス	宿泊施設の予約者最大約445万人	—
アルカディア「SpeeCAN RAIDEN」	不正アクセス	自治体・学校の防災メール等、最大約313.6万件	—
メドレー「@link」	不正アクセス	最大787医療機関	—
日本コロムビアグループ（第一興商の委託先）	従業員PC1台のマルウェア感染	第一興商（ビッグエコー等）約872万件	委託先端末1台から委託元の全顧客に及んだ
ライドオンの利用サーバー運営会社	ランサムウェア	銀のさら・釜寅等 最大約650万件	—
NECの開発・保守委託先	窃取された正規アカウント	NEC顧客のサーバー暗号化	件数非公表
医薬情報ネット	不正アクセス	旭化成Pharma DIGITAL最大約51.4万名	—
バルテック（MOT等の業務SaaS）	自社サービスの脆弱性	勤怠・経費精算・POS等20以上のサービスの利用企業	件数調査中
YCC情報システム、両毛システムズ	ランサムウェア（両毛はVPNアカウント悪用）	山形市などの委託元自治体	—

構造的な含意：波及型では、委託元の公表件数が「可能性」ベースで最大値を出し、後から大きく下方修正される傾向がある（JR東日本、JR九州）。逆に、起点側の最終報で件数が膨らむこともある（Eストアー）。個人情報保護委員会の令和6年度年次報告では、委託先からの漏えい2,248件のうち1,429件（62.8%）が不正アクセスで、報告者本体の漏えい（83.5%がヒューマンエラー）と傾向が大きく異なっていた。

6. なぜ2026年秋に集中したのか

6-1. 公的機関の見解（分かっていること）

- **JPCERT/CC（10/8注意喚起、10/9更新）**：「2026年9月前後」に漏えいが相次いでいるとしたうえで、技術的な情報の共有が不足しており把握している情報は限定的かつ断片的と記した。示された4類型は、A：既知脆弱性の探索と管理不備（環境設定ファイルやバックアップの窃取）、B：API経由の不正操作（アプリ解析によるAPIキー特定、内部APIへの攻撃、NoSQLインジェクション、他システムから窃取したAPIキーの使用）、C：MetabaseのSQLインジェクション（CVE-2026-72898、ゼロデイ攻撃あり）、D：WARファイル型Webシェル。ただし「すべての事案で同一の攻撃手法が使用されていることを示すものではない」と限定している。
- **JPCERT/CC（10/15調査、JPCERT/CC Eyes）**：攻撃インフラの調査で、攻撃者がAIを利用して既知の脆弱性のスキャンやAPI経由での攻撃を実施していたことを確認。攻撃元サーバーにはAPK解析の痕跡、SSRF検証用スクリプト、Flutter解析ツール関連ファイルがあり、日本以外向けのサービスも攻撃していた。どの被害事案かは示していない。
- **NICT（10/13、注意喚起）**：相次ぐ漏えいの「原因の一つ」として「A2B攻撃（App-to-Backend Attack）」を特定。Google Playの日本地域で公開されたAndroidアプリを解析し、接続先サーバーの仕様に合わせて攻撃する手口で、アプリ自体に脆弱性がなくてもサーバー側の認証・認可の不備で漏えいし得る。
- **個人情報保護委員会（10/7）**：WARNINGを改訂し、事例9「APIが悪用される事例」を追加。管理外のAPI、パラメータ書き換えで他人のデータにアクセスできる状態、連番ID、レートリミットの欠如を原因として挙げる。
- **IPA（10/9）**：特定のプロダクトやサービスの脆弱性を狙った攻撃とは断定されておらず、外部公開アプリとアカウント侵害が起点とみられるとした。10/16には事業者向け「不正アクセス特別相談窓口」を開設。
- **国家サイバー統括室（10/9）**：事案を複数確認とし、経営層の関与を求めた。10/14には各機関の注意喚起を1ページに集約。
- **警察庁長官（10/8）**：現時点で事案の背景や相互の関連性は明らかではないと発言。10/15には流出メールアドレス宛ての偽メールに注意を呼びかけ。
- **デジタル大臣（10/2）**：不正目的のおそれによる漏えい等の報告件数は令和6年度7,604件、令和7年度3,822件で、必ずしも増加傾向にあるわけではないと説明。10/6にはパスワード使い回しの中止、多要素認証、不審メールへの注意の3点を国民に要請。
- **官房長官・首相（10/6〜8）**：「大変深刻に受け止めている」と発言。10/8に全府省庁の関係省庁会議があり、国家サイバー統括室に情報を集約。10/21〜22のPHP2Shell対応では高市首相が各組織に対応を呼びかけ、楽天市場・気象庁・ドコモなど多くのサイトが予防的に公開停止・緊急メンテナンスを実施した。
- **総務省・経産省・金融庁（10/9）**：総務省は所管事業者と自治体に注意喚起。経産省は約1,000の業界団体を通じて注意喚起し、提供された情報を同意なく公表しないとした。金融庁は非対面本人確認の徹底を要請。

6-2. 専門家・民間の見方（推測・観測を含む）

- **マクニカら3社の共同資料（10/7）**：攻撃の特徴を「特定の脆弱性だけを探すのではなく、サイトやAPIの不備を広く探る動き」と整理。AIについては断定できるログや痕跡は確認されていないとしつつ「AIの活用を否定する方が難しい状況」とし、ゼロデイがAIで発見・悪用されている状況は確認されていないとした。

- **サイバーセキュリティクラウド（10/9）**：同一とみられる攻撃者が約40分間に326のIPアドレスを使い分け、1,200件超のアクセスを行ったと報告。AIエージェントの可能性を挙げたが、AIの利用を直接示す痕跡を確認したものではないと明記。
- **GMOサイバーセキュリティ byイエラエ（10/19、ScanNetSecurity）**：攻撃元インフラでAI自律型ペネトレーションテストシステム「ARTEX」（中国で開発されたとされ2026年7月にOSS公開、悪用報道を受け10月に公開取りやめ）の使用を確認。標的は日本企業約20社で、うち9社は同業種。同種のAI攻撃インフラを新たに6台発見し、台ごとに主な標的業種が分かれていた。標的企業のうち8社は9〜10月に漏えいを公表済み。**注意点**：約20社すべてが侵害されたわけではなく、8社の社名は公表されていない。
- **ラック（10/15）**：国内法人のWebシステム・アプリ関連の漏えい公表は10月6日時点で119件、うち81件（約68%）が7月以降。同社のサーバー不正侵入対応案件は前四半期の30%から7〜9月は52%に上昇。一方、認知から初回公表までの平均日数は5月の10.9日から9月は2.9日に短縮し、JSOCの不審通信は長期的に大幅増とは評価しにくいとした。倉持CTOも開示時期が9月末に重なった面が大きいとの見方を示している。
- **Cloudflare（10/21〜22）**：PHP2Shellの保護ルールを公開約9時間前から有効化。公開から2時間で数十万件、その後数百万件の攻撃試行を観測。攻撃者はルール回避のためペイロードを変異させ始めており、WAFがあってもパッチ適用を推奨。
- **警察庁の観測**：脆弱性探索などの不審アクセスは2026年上半期に1日・1IPアドレス当たり13,687件で、前年同期比50.7%増。秋のラッシュ以前から探索が増えていたことを示す一次統計。

6-3. 本レポートの判断

- **確認されたこと**：①Web・APIの基礎的な不備（認可、レート制限、管理機能の露出、アプリ埋め込み鍵）と既知脆弱性の広範な探索、②攻撃インフラ上でのAI利用（JPCERT/CC、GMOイエラエ）、③探索アクセスの前年比約1.5倍の増加、④7月以降の公表数の急増。
- **推測にとどまること**：個別の大型事案（タイムズカー、焼肉きんぐ、ソースネクスト、カプコンなど）が同一グループやAIによるものかどうか。被害企業・国による公式の紐付けはない。
- **結論**：秋の集中は、①7〜9月に実際に増えた自動化・AI支援型のWeb/API探索と、②9月末〜10月に調査結果・開示・続報が一斉に出たことの複合である。加えて、③政府の注意喚起（10/7〜9）を受けた点検で過去の侵害が掘り起こされた面もあるとみられる（③は本レポートの推測）。デジタル大臣が示した年度件数の減少は2025年度までの数字で、2026年7月以降の急増を反映していない点に注意が必要である。

---

7. 一次統計との突き合わせ

統計	数値	本レポートとの関係
東京商工リサーチ（2025年）	上場企業と子会社の漏えい・紛失事故は180件（158社）、3,063万6,910人分（前年の約2倍）。原因はウイルス感染・不正アクセスが116件（64.4%）、誤表示・誤送信20.5%、紛失・誤廃棄10.0%	2025年時点で不正アクセスが主因だった
東京商工リサーチ（2026年、10/5時点）	100万件以上が10件（2025年は6件、2023年は8件）。1,000万件以上が3回（2012〜2025年の14年間で3回）。最大はKDDIの1,223万1,954件	10/5以降にソースネクスト、バーガーキング、カプコン、skyticketが加わり、本レポートの集計では1,000万件超が8件（非上場・全世界件数を含む）
警察庁 令和8年上半期	ランサムウェア123件（半期最多、前年同期116件）。中小企業79・大企業31・団体13、製造業37。感染経路は有効回答36件中VPN18・リモートデスクトップ9・その他9。復旧費用1,000万円以上が6割、1か月未満で復旧したのは5割弱。不審アクセス13,687件/日・IP（+50.7%）	内訳の一部は警察庁PDFを直接確認できず、@IT・sqat・SPネットワーク等の引用で照合。ノーウェアランサム9件は単一の二次情報のみのため**未確認**

統計	数値	本レポートとの関係
個人情報保護委員会	民間の漏えい等報告は令和6年度19,056件（過去最多）、令和7年度17,139件（行政機関等2,278件）、令和8年度第1四半期6,101件	2026年4〜6月は四半期として高水準。秋のラッシュ分は第3四半期以降に計上される見込み
金融庁 証券口座不正取引（2026年10月版）	2025年：不正取引9,861件、売却約3,949億円・買付約3,468億円（ピークは2025年4月）。2026年1〜9月：781件、売却約423億円	2025年はフィッシングによる口座乗っ取りが中心。2026年は大幅に減り、漏えいの主戦場はWeb/API型に移った（暫定値、売買代金は被害額ではない）

8. 10月20日以降の最新動向（10/23 0時時点）

- **カプコン「CAPCOM ID」（10/22）**：10/19に不正アクセスの痕跡を発見して遮断、同日に侵害を確認。全世界合計11,774,247件のメールアドレスとシステム固有の識別情報（作成日時、最終ログイン日時、ログイン回数、最終ログイン時のIP）が漏えい。うち43件は生年月日・性別・国・ニックネーム、196件でパスワードの不正変更（リセット済み）。パスワード本体とカード情報は対象外。「攻撃手段の特定と対応は完了」としているが手口は非公表。サービスは停止せず継続。
- **バルテック（10/22）**：第一報で「PHPの脆弱性を標的としたサイバー攻撃」として国内初のPHP2Shell被害と受け止められたが、同日夜に「PHPの脆弱性によるものではなく、自社サービス自体の脆弱性」と訂正（PHP対応を同時進行していたための混同と説明）。MOT、勤怠・経費精算、POSなど20以上のサービスを停止、最短10/26復旧予定。件数は調査中。
- **PHP2Shell（CVE-2026-109618/109619、CVSS v4.0 9.2、未認証RCE）**：10/21に修正版（8.5.12/8.4.27/8.3.36/8.2.35）が公開。8.1以前は公式修正なし。国内ではエックスサーバー、BASE、カラーミーショップ、さくらインターネット、Movable Typeクラウド、お名前.comレンタルサーバー、Studioなどが予防停止・パッチ適用を公表。楽天市場や気象庁なども緊急メンテナンスを実施。**10/22時点でこの脆弱性による国内の侵害を公表した組織はなく、バルテックの訂正によりゼロのまま。**
- **ソフトバンク（10/19〜22）**：10/17に「My SoftBank」関連システムで不正アクセスの試みを監視システムが検知し、Web版3サイトを停止。10/21にMy SoftBank、10/22にMy Y!mobileとMy Menuを再開。漏えいの公表はなし。
- **お名前.com デスクトップクラウド（10/21〜22）**：10/19に顧客の問い合わせで調査開始、10/20に不正プログラムの設置を確認、10/21 4:00から全プランを順次停止。第2報（10/22）で、取引ツール（MT4/MT5等）に保存された口座ログイン情報が取得され、取引口座で第三者による不正な操作が行われたとの報告を受けていると公表。10/22に警察へ相談。影響の可能性があるサーバーは26,739件。侵入経路は調査中。
- **NEC委託先事案（10/20）**：委託先へのサイバー攻撃で窃取された正規アカウントが悪用され、顧客のサーバーのファイルが暗号化された。件数は非公表。大阪大学が委託先NECからの個人情報漏えいを公表。
- **コミックシーモア（10/21第4報）**：ログ上最大約420万件（重複あり、パスワードなし）と会員DB 319件。停止中、閲覧機能から段階的に再開する方針。
- **その他（10/19〜22）**：Renta!（停止中、件数未公表）、ニフティ（最大542,513件、KDDI事案とは別件）、H2O ID（約126万件）、ユミルリンク Cuenote FC（延べ約900万件、利用企業側の公表が続く見込み）、あきる野市（職員約500人）。
- **政治の動き**：チームみらいがサイバー攻撃と情報漏洩に関する緊急提言を10/23に政府へ手交予定と発表（10/22）。

9. 被害を受けた側・利用者への影響

- **免許証画像の流出と本人確認制度**：タイムズカーで約160万件の本人確認書類画像が流出。愛知県（10/1）と新潟県（10/2）の公安委員会は流出対象者に特例で免許証の再交付（番号・顔写真の変更）を認めた。金融庁は10/9、2027年4月1日施行の犯収法施行規則改正（画像送信方式を廃止しICチップ読取に原則一本化）を施行日を待たず前倒しするよう金融機関に要請。
- **パスワード使い回しによる実害**：infoQでポイント不正交換611件・計2,869,500円分（10/5時点）、お名前.comでFX・証券口座の不正操作報告、カプコンで196件のパスワード不正変更、ソースネクストはパスワードを含む最大2,252万件、KDDIはメールパスワード約762万件。
- **フィッシングの警告**：警察庁は10/15、流出したメールアドレスに届く漏えい元企業をかたる偽メールへの注意を呼びかけた。日経では社員アカウントからなりすましメール約9,000件が送信され、それを起点に日経BPでも認証情報が窃取された。漏えいがフィッシングを生み、それがさらに漏えいを生む連鎖が実際に起きている。
- **業務停止の影響**：IDCFの利用495組織、京王の決済・ポイント、大阪公立大学の約1週間の休講、電子書籍2サービスの全面停止、バルテックの業務SaaS20以上、メドレー@linkを使う医療機関など、漏えい件数に表れない損失が大きい。

---

10. 構造的な問題点

1. **「公開アプリ＝サーバー仕様の地図」問題**：アプリに埋め込まれたAPIキーや秘密鍵、クライアント側の処理を前提にした認証、サーバー側の認可（誰のデータか）の欠落が、A2B攻撃と大量取得を許した。
2. **集約された会員基盤・共有基盤**：1つの会員IDやマルチテナント基盤に顧客情報を集めた結果、1回の侵害が1,000万件級、数千店舗級の被害になった。
3. **不要データの保持**：skyticketの2018年以前の決済ログ、タイムズカーの退会者の免許証画像の長期保管など、「消していなかった」ことが被害を広げた。
4. **開示の質のばらつき**：主要事案の67%で手口が分からず、他社が教訓を引き出せない。JPCERT/CCも技術的な情報の共有が不足と明言している。
5. **最大値ベースの初報と後からの訂正**：JR東日本・JR九州の「漏えいなし」、skyticketのカード情報の追加、Eストアーの件数修正、バルテックの原因訂正など、件数・項目・原因が続報で大きく動いた。

11. 示唆

事業者向け（優先順）

1. 直近1か月、続けて3か月分のAPI・管理機能のログを点検する。見る点は、大量取得、403/404/503の急増、作った覚えのないアカウント（IPA・専門家共同資料の推奨）。
2. 全APIを棚卸しし、エンドポイントごとの認可、レート制限、連番IDの廃止、レスポンスの最小化を行い、アプリへの秘密鍵の埋め込みをやめる（PPC事例9、JPCERT/CC、NICT）。
3. 委託先・SaaSを自社と同じ基準で点検する。管理サイトにフィッシング耐性のある多要素認証を入れ、テナントを分離し、委託先端末を管理する（i-ask、第一興商、NEC）。
4. 不要データ（退会者情報、本人確認画像、古いログ）を削除する。本人確認はICチップ読取に前倒しで移行する。
5. PHP2Shellなど既知脆弱性の緊急パッチを当てる。WAFがあることを理由にパッチの優先度を下げない。

6. 被害時は手口を含めて公表し、国家サイバー統括室や所管省庁へ技術情報を共有する。経産省は、提供された情報を同意なく公表しないとしている。

個人向け

1. サービスごとに異なるパスワードを使う（パスワードマネージャーに任せる）。ソースネクスト、KDDI、Gyazo、skyticket、カプコンの利用者は直ちに変更する。
2. 多要素認証を有効にする。特に証券・FX口座は必須。お名前.comデスクトップクラウドの利用者は、サーバー以外の端末から口座パスワードを変更する。
3. 漏えい元をかたるメールやSMSのリンクは開かず、公式アプリやサイトから確認する。
4. 免許証画像が流出した場合は、再交付の特例（各県公安委員会）の利用を検討し、身に覚えのない契約や信用情報を定期的に確認する。

留意事項

- 主要60件は網羅的な母集団ではなく、10万件以上または社会的影響が大きい事案を抽出したものである。構成比はこの抽出に依存する。民間集計では、9月25日〜10月8日だけで第1報36件（westeria.jp）、Web関連の公表119件（ラック、10/6時点）が確認されている。
- 数値の不一致：セイコーマート（572,022人／574,647人）、infoQ（894,082件／最大948,498件）、KDDI（1,223万3,087件／12,231,954件）は公表時点の違いと考えられるため併記した。
- 2りんかんイエローハット（3,179,454名、API悪用）、Klue（Salesforce連携悪用で国内外約24社）、ノーウェアランサム9件は、民間まとめサイトまたは単一の二次情報でしか確認できず、**未確認**である。
- 警察庁の上半期報告PDFは直接参照できず、内訳は複数の専門メディア・事業者による引用の一致で確認した。金融庁の数値は暫定値。
- 攻撃者による犯行声明のみの事案（IDCFに関するSNS上の声明など）は、事実として扱っていない。

主な出典

- JPCERT/CC「連続不正アクセス事案の攻撃手法に関する調査」 https://blogs.jpcert.or.jp/ja/2026/10/web_api_attacks.html
- NICT「相次ぐ情報漏えい、その原因の一つは『アプリ解析からのサーバ攻撃』」 https://www.nict.go.jp/press/2026/10/13-1.html
- piyolog「国内で相次ぐ不正アクセスに対する注意喚起についてまとめてみた」 https://piyolog.hatenadiary.jp/entry/2026/10/11/004353
- マクニカ「相次ぐWEBシステムからの情報漏洩事案について」 https://security.macnica.co.jp/blog/2026/10/web-incidents2026.html
- 東京商工リサーチ「上場企業『個人情報漏えい』、過去最悪ペース」 https://www.tsr-net.co.jp/data/detail/1203305_1527.html
- ScanNetSecurity「GMOサイバーセキュリティ byイエラエ、不正アクセス攻撃元にAI自律型ペンテストシステム『ARTEX』を確認」 https://scan.netsecurity.ne.jp/article/2026/10/21/56522.html
- GMOインターネットグループ「お名前.com デスクトップクラウド」第2報 https://group.gmo/info/alert/20261022/
- Cloudflare「Cloudflare deploys protections against php2shell vulnerability」 https://blog.cloudflare.com/php-vulnerabilities-waf-protection

- ウェステリア「国内のデータ流出・不正アクセス事案まとめ」 https://westeria.jp/security-incidents/